

Privacy Policy & Terms of Use

HairOriginals AI Try-On — revision 2, aligned to the storefront policies

WHAT CHANGED IN THIS REVISION

Company details are no longer blank. The operating entity, registered address, CIN, and Grievance Officer are now taken from the published storefront policies, so the app names the same legal entity as hairoriginals.com. Both documents now also carry a governing-law clause, an intellectual-property clause, and an explicit statement of how they relate to the storefront's own policies — none of which the previous draft had.

The Privacy Policy also carries a new prominent **"We do not sell your data"** section, replacing a single buried line. It states the no-sale position in the terms US state law uses ("money or other valuable consideration"), confirms that the named providers are processors who cannot use the data for their own ends, and discloses the one arguable exception: ad measurement events sent to Meta after consent, which some US statutes treat as "sharing" even though nothing is sold. Overstating this would be a deceptive-practice risk in itself, so it is stated precisely rather than absolutely.

What we need from you

1. **Confirm the two values that are not from the storefront policies** — the privacy contact mailbox and the minimum age. Section 1 marks both.
2. **Decide the six open points** in Section 2. Each is a business or legal choice; the draft answers each one way and says so.
3. **Approve or amend the text** in Sections 3 and 4. Marking up this document is fine.

One thing to be aware of before reading. The storefront privacy policy does not cover this product's main risk. It makes no mention of image or biometric processing, names no third-party processors, states no retention periods, and limits itself to Indian jurisdiction. This app uploads photographs of users' faces to Google for processing — special-category data under GDPR Article 9 and biometric data under several US state statutes. The app-specific sections in Section 3 therefore *add to* the storefront policy and cannot be replaced by linking to it. Section 5 sets out the gap in detail.

Sections 3 and 4 are the complete live text of both documents. They were drafted to describe what the application actually does, so the disclosures are accurate — but they have **not been reviewed by a lawyer** and are not legal advice.

Product HairOriginals AI Try-On (web app)

Entity KrisOriginals Pvt. Ltd — CIN U51909HR2018PTC074470

Documents Privacy Policy; Terms of Use

Revision date 8 August 2026

Markets India plus international, including EEA/UK and the US

Prepared by Engineering

SECTION 1

Company details, as now published

These values are live in both documents. Everything unshaded was taken from the storefront's published privacy policy and terms; the two shaded rows are app-specific choices that need your confirmation.

FIELD	VALUE NOW PUBLISHED	SOURCE
Legal entity	KrisOriginals Pvt. Ltd, trading as HairOriginals	Storefront privacy policy
CIN	U51909HR2018PTC074470	Storefront privacy policy
Registered address	Plot No. 220, Udyog Vihar, Phase IV, Sector 18, Gurugram, Haryana – 122015, India	Storefront privacy policy
Privacy contact	<code>aniket.kushwaha@hairoriginals.com</code>	Not from storefront — supplied for this app. Confirm this mailbox will be monitored.
Grievance Officer	Mayank Sharma — <code>feedback@hairoriginals.com</code> , +91 9267993875	Storefront privacy policy
Order support	<code>help@hairoriginals.com</code> , +91 8700797103	Storefront privacy policy
Minimum age	<code>16</code>	Diverges from storefront , which states 13. See item 2.1.
Governing law	India; exclusive jurisdiction of the courts at Gurugram, Haryana	Derived from the storefront's India-operated clause and registered office
Last updated	8 August 2026	Set to this revision. Change to your approval date if later.

Engineering note: all of the above live in one configuration file and propagate to both documents automatically. Changing any value is a one-line edit, not a rewrite.

Two answers we need in writing

1. Is `aniket.kushwaha@hairoriginals.com` the right destination for data-deletion requests? It is a named individual rather than a role mailbox, so it will break when that person is unavailable or leaves. If you would rather this go to a role address — `privacy@`, or the existing `feedback@` that the Grievance Officer already uses — say so and we will change it.

2. Is `16` the right minimum age? The storefront says 13. We set 16 for the app because it collects facial images, and 16 is the highest digital-consent age used across EEA member states. Item 2.1 explains what 16 still leaves exposed.

SECTION 2

Open points needing a decision

Six items. Each is a choice the draft currently answers one way, stated below so you can confirm or overrule it. Two items from the previous revision are now closed and noted at the end.

2.1 Minors' facial images **HIGHEST EXPOSURE**

The app is set to 16+, above the storefront's 13, because a facial image processed to generate a likeness is special-category data under GDPR Article 9 and "biometric information" under several US state statutes.

16 does not remove the exposure — it narrows it. A 16- or 17-year-old is still a minor, and their biometric data attracts the same treatment. The concrete risk is the **Illinois Biometric Information Privacy Act**: statutory damages of **USD 1,000 per negligent violation and USD 5,000 per reckless violation**, assessed per person, with a private right of action. BIPA also requires a *written* release and a *published written retention and destruction schedule* before collection — obligations that go beyond a tick-box.

Separately, no age verification is performed. The requirement is stated in the terms, but users are never asked to confirm their age, so nothing prevents a 12-year-old from uploading a photo.

Current position: 16+ stated in the terms; explicit tick-box consent before each upload; no age check.

Decisions needed: (a) Confirm 16, or raise to 18 to keep minors' biometric data out entirely. (b) Should we add an age self-declaration at signup, so the requirement is affirmative rather than merely stated? (c) Is tick-box consent sufficient, or do we need a distinct written biometric release and a published destruction schedule for BIPA? (d) Should we geo-block Illinois rather than accept the exposure?

2.2 No automated deletion mechanism exists **HIGH**

The policy promises deletion within 30 days of a request. There is **no self-service delete button and no automated deletion job** in the product — the promise can only be met by someone reading the privacy mailbox and acting on it by hand.

This now depends on a single named address (see Section 1). A commitment we cannot operationally honour is worse than no commitment, because it converts an ordinary backlog into a breach of our own published policy.

Decision needed: Either (a) confirm a named owner and a backup will monitor the mailbox and action requests from launch, or (b) instruct us to build a self-service deletion flow before launch.

2.3 Photos are stored indefinitely, not discarded **HIGH**

Both the uploaded photograph and every generated image are retained so users can revisit past try-ons in a "My Looks" gallery. Deleting the source photo immediately after generation would remove that feature but would sharply cut the volume of biometric data held at rest — and would largely answer the BIPA destruction-schedule point in 2.1.

Current position: retained while the account is active; deleted within 30 days of a request, subject to legal retention obligations.

Decision needed: Accept indefinite retention, or set a hard automatic expiry — for example, delete source photos after 30, 90, or 180 days whether or not the user asks?

2.4 Photos are sent to Google for processing **MEDIUM**

Generation is performed by Google's Gemini API. The user's photograph and the product image leave our infrastructure and are processed by Google, potentially outside the user's own country. We do not use uploaded photos to train any model, and the policy says so.

The storefront privacy policy names no third-party processors at all, so this disclosure exists only in the app policy.

Current position: Google named explicitly; cross-border transfers stated to rely on the provider's standard contractual clauses or equivalent safeguards.

Decision needed: Confirm whether a Data Processing Addendum with Google is executed, and whether you want the specific transfer mechanism named in the text rather than described generically.

2.5 Cookie consent is shown only in Europe **MEDIUM**

The consent banner appears based on the visitor's browser timezone: EEA, UK, and Swiss visitors must opt in before any analytics or advertising script loads. Elsewhere those scripts load without a prompt. Timezone detection is approximate — a VPN or a traveller defeats it.

One strictly necessary cookie meters free try-on credits and is not optional; this is disclosed.

Decision needed: Accept the region-based approach, or require opt-in for *all* visitors worldwide? Universal opt-in is easier to defend and removes the geolocation-accuracy problem, at some cost to analytics coverage and ad measurement.

2.6 Cookie consent cannot be withdrawn in the app MEDIUM

The consent decision is stored in the visitor's browser and the banner is never shown again. There is **no cookie-settings screen and no way to change the answer** once given. GDPR Article 7(3) requires that withdrawing consent be as easy as giving it, so an accept-once-forever design is the weak point here — not the banner itself.

The policy therefore tells users the honest workaround: clearing the site's browser data resets the choice. That is accurate but is not what Article 7(3) has in mind.

Decision needed: Should we build a cookie-settings control that lets users change their answer, and a matching link in the app footer? This is a small piece of work and it removes the Article 7(3) argument entirely.

Closed since the previous revision

CLOSED **Blank company details.** All six placeholders are filled from the storefront policies and no longer render as visible `TODO` text to users.

CLOSED **Missing terms clauses.** Governing law and jurisdiction, an intellectual-property clause, and a user indemnity for photos uploaded without permission have been added to the Terms. A formal arbitration clause is still absent — tell us if you want one.

Privacy Policy

Last updated: 8 August 2026 · Shaded values are app-specific rather than taken from the storefront policies.

This policy explains what the HairOriginals AI Try-On app collects, why, who it is shared with, and how to get it deleted. It adds to the HairOriginals privacy policy rather than replacing it: the storefront policy governs browsing and purchases, while this one covers the photo you upload here and everything the try-on does with it.

Who controls your data

KrisOriginals Pvt. Ltd (CIN U51909HR2018PTC074470), trading as HairOriginals, of Plot No. 220, Udyog Vihar, Phase IV, Sector 18, Gurugram, Haryana – 122015, India, is the controller of the personal data described here. Privacy requests go to aniket.kushwaha@hairoriginals.com.

Purchases on the HairOriginals storefront are governed by the storefront privacy policy. Where the two documents differ on the handling of photos you upload to this app, this policy applies.

Your photo, and why it needs special consent

The core feature requires a photo of your face. A facial image processed to generate a likeness is treated as **biometric / special-category data** under the EU/UK GDPR (Article 9) and under US state biometric laws including the Illinois Biometric Information Privacy Act. We process it only on your **explicit consent**, which you give by ticking the consent box before uploading. The box is unticked by default and is asked again for each new photo, so consent is never assumed from a previous try-on. You can withdraw consent at any time by requesting deletion.

Your uploaded photo is **stored**, not discarded after processing, so your past try-ons remain visible in "My Looks". Both the original photo and each generated image are retained until you request deletion or the retention period below elapses.

We do not use your photo to train any AI model, and we do not use it for facial recognition, identification, or matching you against any database.

What else we collect

- **Phone number** — used to sign you in via one-time code, and as your account identifier.
- **Name and email** — only if you provide them when requesting a stylist consultation.
- **Device and usage data** — a hashed device fingerprint, a hashed IP address, and a device cookie. These exist to meter free try-on credits and prevent abuse; this is strictly necessary to run the service.
- **Try-on activity** — which products you viewed, tried, and saved, plus any feedback or rating you submit.

Who we share it with

- **Google (Gemini API)** — receives your uploaded photo and the product image in order to generate the try-on. Processing occurs on Google infrastructure, which may be outside your country.

- **Supabase** — database, authentication, and image storage.
- **Digicuro CRM** — if you request a stylist consultation, your contact details and links to your generated looks are sent so a stylist can follow up.
- **SMS providers** — your phone number is sent to the provider that delivers your one-time code (Nimbus for Indian numbers, Twilio elsewhere).
- **Meta** — if you accept analytics cookies, we send advertising measurement events. Email and phone are hashed before sending; your IP address is sent to Meta as part of this.

Transfers outside your region rely on the relevant provider's standard contractual clauses or equivalent safeguards.

We do not sell your data

We do not sell, rent, or trade your personal data, and we never disclose it to anyone in exchange for money or other valuable consideration. That covers your photos, your generated looks, your phone number, and your try-on history. We have no data-broker relationships and we do not license your data to anyone.

The companies named above are service providers working on our instructions. They may use your data only to deliver the specific service we have asked them for, and not for their own purposes. Your photo goes to Google to generate your try-on and for nothing else — not to train their models, and not to build a profile of you.

To be straightforward about the one exception: if you accept analytics cookies, we send advertising measurement events to Meta. No money changes hands, but some US state privacy laws still classify that as "**sharing**" for **cross-context behavioural advertising**, so we would rather name it than let you find out later. Decline cookies and it never happens. If you have already accepted and want to undo it, clearing this site's data in your browser resets the choice and we will ask you again.

Where we operate

We are established in India and the app is operated from there, but it is available to users elsewhere. Where you are in the EEA, the UK, or a US state with its own privacy or biometric statute, we apply the protections that law gives you — including the consent, access, and deletion rights set out below — regardless of where we are based.

Cookies and tracking

A device cookie is set to track your free credits — this is strictly necessary and is not optional. Analytics and advertising scripts (Meta Pixel, Vercel Analytics) load **only after you accept** where consent is required, and never before. Declining leaves the app fully functional.

How long we keep it

Photos, generated images, and account data are kept while your account is active. If you request deletion we remove them within 30 days, except where we are required to retain records by law.

To ask for deletion, email aniket.kushwaha@hairoriginals.com from the address or phone number on your account, or contact the Grievance Officer below. Deleting your photos does not affect any order you have placed on the storefront.

Your rights

Depending on where you live, you may have the right to access, correct, delete, port, or restrict processing of your data, to object to processing, and to withdraw consent at any time without affecting prior processing. EEA/UK users may also complain to their local supervisory authority.

To exercise any of these, email aniket.kushwaha@hairoriginals.com. We respond within the period required by applicable law.

Children

The app is not intended for anyone under 16, and we do not knowingly collect data — least of all facial images — from anyone below that age. If you believe someone underage has used the app, contact us and we will delete the data.

Grievance officer (India)

Under the Digital Personal Data Protection Act 2023, Indian users may contact our Grievance Officer, Mayank Sharma, at feedback@hairoriginals.com or +91 9267993875.

Terms of Use

Last updated: 8 August 2026 · Shaded values are app-specific rather than taken from the storefront policies.

These terms govern your use of the HairOriginals AI Try-On app. By using the app you agree to them. They sit alongside the HairOriginals storefront terms, which continue to govern anything you buy.

Who you are contracting with

The app is operated by KrisOriginals Pvt. Ltd (CIN U51909HR2018PTC074470), trading as HairOriginals, of Plot No. 220, Udyog Vihar, Phase IV, Sector 18, Gurugram, Haryana – 122015, India.

What the service does

The app generates an AI preview of how a HairOriginals product might look on you, from a photo you upload. Previews are illustrative only. They are machine-generated approximations and will not exactly match the real product on your hair — colour, texture, density, and fit vary in reality.

Your account

Accounts are created and accessed with a one-time code sent to your phone. You are responsible for keeping access to that number secure, and for activity under your account. You must be **16** or older to use the app. If you are under 18, you may use it only with the consent of a parent or guardian.

Photos you upload

You confirm that, for every photo you upload:

- it is of you, or you have the permission of the person shown;
- you have the right to upload it and to have it processed as described in the Privacy Policy;
- it does not contain anyone under **16**.

You keep ownership of your photos. You grant us a limited licence to process, store, and display them solely to provide the try-on service to you. That licence ends when you delete the content or your account.

If you upload a photo of someone else without their permission, you are responsible for any claim that results from it.

Acceptable use

You must not:

- upload photos of other people without their permission;
- use the app to create misleading, defamatory, or explicit imagery;
- attempt to bypass credit limits, rate limits, or authentication;

- scrape, resell, or automate access to the service.

We may suspend accounts that breach these terms.

Credits

Try-ons are metered with credits. Credits have no cash value, are not transferable, are not refundable, and may be changed or withdrawn at any time.

Our content

The app, its product imagery, and the HairOriginals name and marks belong to us or our licensors. Generated previews are provided for your personal use; you may share them, but you may not use them to advertise or sell anything.

Products and purchases

Prices shown in the app are indicative and may differ from the storefront at checkout. Purchases happen on the HairOriginals storefront and are governed by its own terms and conditions, including everything to do with payment, shipping, returns, and exchanges — not these terms.

Availability and liability

The app is provided "as is", without warranty of any kind. We do not guarantee uninterrupted availability, and generation may fail or be delayed. To the fullest extent permitted by law, we are not liable for indirect or consequential loss, or for decisions made on the basis of a generated preview. Nothing here limits liability that cannot be limited by law, including for death or personal injury caused by negligence.

Governing law

These terms are governed by the laws of India, and the courts at Gurugram, Haryana, India have exclusive jurisdiction over any dispute. If you are a consumer resident elsewhere, this does not remove any protection your local law gives you that cannot be waived by agreement.

Changes and contact

We may update these terms; material changes will be reflected in the "last updated" date above. Questions about the app or your data go to aniket.kushwaha@hairoriginals.com. For help with an order, contact help@hairoriginals.com or +91 8700797103.

Still not addressed, if you want it: a formal arbitration or dispute-resolution procedure, and a monetary cap on liability. The draft relies on the general limitation clause above.

What the app collects, and what the storefront policy misses

Taken from the implementation rather than from the policy, so you can verify the disclosures in Sections 3 and 4 without reading source code.

Gap against the storefront privacy policy

Each row is something the app does that the published storefront policy does not address. This is why the app needs its own document rather than a link.

STOREFRONT POLICY	WHAT THE APP ACTUALLY DOES	CONSEQUENCE
No mention of images, photographs, or biometric data	Collects and stores facial photographs; sends them to a third party for AI processing	No lawful basis disclosed for special-category data. GDPR Art. 9 and BIPA both require notice and consent specific to biometrics.
Names no third-party processors, only generic categories	Sends data to Google, Supabase, Digicuro, Nimbus, Twilio, Meta, Vercel	GDPR Art. 13 expects recipients or categories to be identified. Naming them is the safer reading.
States no retention periods	Retains photos and generated images indefinitely while the account is active	BIPA requires a published retention and destruction schedule before collection.
"Not intended to subject us to the laws or jurisdiction of any ... other than India"	Gates cookie consent for EEA/UK visitors; routes SMS via Twilio for non-Indian numbers	The product is built for international users, so the India-only stance does not describe it. Section 3 states this openly instead.
Age threshold of 13	Set to 16 for the app	Deliberate divergence — see item 2.1.
No "last updated" date, despite referring to one	Both app documents display 8 August 2026	Worth fixing on the storefront too; a policy that cites a date it does not show is a weak point.

Data inventory

DATA	PURPOSE	STORED WHERE	BASIS IN DRAFT
Facial photograph	Input to AI generation; retained for the "My Looks" gallery	Supabase storage; transmitted to Google Gemini	Explicit consent, per photo
Generated try-on images	Delivering the result; saved history	Supabase storage	Explicit consent / contract
Phone number	One-time-code sign-in; account identifier	Supabase auth; sent to Nimbus (India) or Twilio (elsewhere)	Contract — necessary to provide the service
Name and email	Stylist consultation follow-up	Supabase; forwarded to Digicuro CRM	Consent — only if a consultation is requested
Hashed device fingerprint	Metering free credits; abuse prevention	Supabase	Legitimate interests — strictly necessary
Hashed IP address	Rate limiting; abuse prevention	Supabase	Legitimate interests — strictly necessary
Device cookie	Tracking free-credit balance	User's browser	Strictly necessary — not subject to consent
Try-on activity	Product analytics; feedback	Supabase	Legitimate interests
Ad measurement events	Ad performance measurement	Sent to Meta	Consent — only after the user accepts

Things the app does not do

Stated so the policy's negative claims can be verified: uploaded photos are not used to train any AI model; there is no facial recognition, identification, or matching against any database; no personal data is sold, rented, traded, or disclosed for money or other valuable consideration; there are no data-broker relationships; and no analytics or advertising script loads before consent where consent is required.

The one qualification on the no-sale claim is the Meta ad-measurement flow, which fires only after consent and transfers no money. It is disclosed in the policy under the same heading as the no-sale statement rather than being left for a reader to discover in the sharing list.

Regulatory exposure by market

MARKET	REGIME	PRINCIPAL OBLIGATION TRIGGERED
India	DPDP Act 2023	Named Grievance Officer with published contact details; notice at collection. Verifiable parental consent is required for anyone under 18, which the 16+ threshold does not satisfy on its own.
EEA / UK / Switzerland	GDPR & UK GDPR; ePrivacy	Art. 9 explicit consent for biometric data; Art. 13 notice; prior consent before non-essential cookies; safeguards for international transfers
Illinois, USA	BIPA	Written release before collection; published retention and destruction schedule; USD 1,000–5,000 statutory damages per violation, private right of action
Texas / Washington, USA	CUBI; My Health My Data	Consent before capture of biometric identifiers; no private right of action in Texas, but Washington's statute does provide one
California, USA	CCPA / CPRA	Biometric data is "sensitive personal information": notice, right to limit use, and deletion rights

This annex is a factual description of the software, compiled by engineering. The regulatory column indicates why review is needed; it is not a legal conclusion about compliance. Note in particular the India row: the DPDP Act treats everyone under 18 as a child requiring verifiable parental consent, which is a live question for the 16+ threshold in item 2.1.

Sign-off

REVIEWED BY

DATE

APPROVED FOR LAUNCH / APPROVED SUBJECT TO THE CHANGES MARKED ABOVE (DELETE AS APPLICABLE)